

Compliance Auditing Basics

Audit Plan, Evidence Collection & Remediation Plan — HIPAA Security Rule Technical Safeguards (Access Control & Audit Controls)

Scenario organization: Horizon Valley Medical Center (HVMC)

Capstone project: AccessGuard Health — Azure/Entra ID & AWS IAM Operations

Rubric item: Compliance Auditing Basics

Compliance area audited: HIPAA Security Rule — Technical Safeguards, 45 CFR §164.312

Reference source: HIPAA Journal, *HIPAA Compliance Checklist*

Report date: October 6, 2026

This audit plan and its findings are prepared as a classroom lab exercise for the HVMC simulation used in this capstone. Findings, evidence references, and risk ratings are illustrative, built against the lab's AD/Entra ID/AWS IAM environment rather than a live production system, and do not constitute a real HIPAA compliance certification. The HIPAA Journal checklist referenced throughout is used as a general informational reference only and is not legal advice.

Rubric Cross-Reference

Rubric Requirement	Where Addressed
Create an audit plan for one compliance area including scope definition, methodology, timeline, and resource requirements	Section 1 — Audit Plan (§1.1–1.4)
Collect and document evidence for three compliance controls using proper procedures including evidence types, collection techniques, and documentation standards	Section 2 — Evidence Collection for Three Compliance Controls
Perform compliance assessment using testing methodologies and document findings with gap analysis	Section 3 — Compliance Assessment
Create remediation plan with prioritized recommendations, implementation timeline, and progress tracking methods	Section 4 — Remediation Plan

1. Audit Plan

1.1 Compliance Area & Scope Definition

The HIPAA Journal checklist used for this audit organizes HIPAA obligations into five areas: Security Rule Physical Safeguards, Security Rule Administrative Safeguards, Security Rule Technical Safeguards, Privacy Rule requirements, and Breach Notification requirements. This audit selects **Security Rule — Technical Safeguards (45 CFR §164.312)** as its one compliance area, because this is the area HVMC's capstone lab environment generates direct, testable evidence for: the on-premises Samba4 Active Directory domain, the Entra ID tenant, and the AWS IAM environment that together govern every HVMC workforce member's access to electronic protected health information (ePHI).

In scope:

- On-premises identity store: Samba4 Active Directory Domain Controller (Ubuntu Server), organizational units, security groups, and the domain password/lockout policy (`samba-tool domain passwordsettings`)
- Cloud identity: Microsoft Entra ID tenant — users, groups, Enterprise Applications, and Conditional Access/MFA policies
- Cloud infrastructure access: AWS IAM users, groups, roles, and tag-based (ABAC) policies supporting the hospital's cloud workloads
- Federated single sign-on: the Authentik-based SAML federation used for one HVMC application

- Logging and monitoring: AWS CloudTrail, VPC Flow Logs, and GuardDuty, plus Samba4 authentication logs
- The Joiner–Mover–Leaver (JML) lifecycle activities already executed in the lab (Onboarding, Transfer, Termination, MFA Support, Access Review), which are the primary evidentiary basis for this audit

Out of scope: Physical Safeguards (badge/door access, device asset logs), Administrative Safeguards (training records, Business Associate Agreements), Privacy Rule patient-rights procedures, and Breach Notification procedures are addressed elsewhere in the capstone's compliance deliverables and are not re-tested here.

1.2 Audit Methodology

The audit follows a standard three-step control-testing methodology, applied to each of the three controls in Section 2:

- **Inquire** — interview the control owner (the IAM/Identity administrator role in the lab) to understand how the control is intended to operate.
- **Examine** — review supporting documentation: AD/Entra ID/AWS IAM configuration exports, the HVMC access-control policy, and prior JML activity tickets.
- **Test** — independently verify the control is operating as documented by pulling live evidence (console screenshots, CLI output, exported logs) and comparing it against the requirement.

Results of each test are scored against the corresponding HIPAA Journal checklist item and 45 CFR citation, then carried into the gap analysis in Section 3.3.

1.3 Audit Timeline

Date	Phase	Activities
Mon, Sep 29	Planning	Confirm scope and the three controls to test; notify the control owner; prepare the evidence log template.
Tue, Sep 30	Fieldwork — Evidence Collection	Collect evidence for all three controls (Section 2); log each item with source, date, and collector.
Wed, Oct 1	Fieldwork — Testing & Assessment	Apply the Inquire/Examine/Test methodology; cross-reference AD/Entra/AWS IAM configuration to the chosen framework; draft gap analysis.
Thu, Oct 2	Reporting	Finalize findings and risk ratings; draft the remediation plan; package the management-facing report.
Fri, Oct 3	Close-out	Walk through findings with the control owner; confirm remediation owners and target dates; archive evidence.

1.4 Resource Requirements

Resource	Role in This Audit
Compliance Auditor (capstone learner, acting role)	Plans and executes the audit; collects and documents evidence; writes findings and the remediation plan

IAM/Identity Administrator (acting role)	Control owner for AD, Entra ID, and AWS IAM; provides configuration access and answers inquiry questions
HR / Workforce Alliance liaison (acting role)	Confirms workforce roster used to validate unique-identity and access-review evidence
Systems & access	Read-only access to the Entra ID admin center, AWS IAM console, Samba4 domain controller shell, and CloudTrail/GuardDuty consoles
Tools	Audit evidence log (spreadsheet), screenshot capture, samba-tool CLI, AWS CLI/console exports
Time budget	Approximately 6–8 hours across the 5-day window above

2. Evidence Collection for Three Compliance Controls

The three controls below are drawn directly from the *Technical Safeguard Requirements* section of the HIPAA Journal checklist, selected because HVMC's IAM lab environment produces direct, verifiable evidence for each.

Control 1 — Unique User Identification

Checklist item: "Control access to ePHI with unique usernames or codes for each user" · 45 CFR §164.312(a)(2)(i)

Evidence Type	Exported user/account listings; screenshots of individual account properties
Collection Technique	Export the full user list from the Samba4 domain (<code>samba-tool user list</code>), the Entra ID tenant (Entra admin center → Users), and the AWS IAM console (IAM → Users); spot-check a sample of 5 accounts from each JML activity (Onboarding, Transfer, Termination, MFA Support) to confirm one account per person with no shared logins
Documentation Standard	Evidence is logged in the audit evidence log with: control ID, evidence description, source system, collection date, collector name/role, and a file reference to the exported list or screenshot. Each sampled account is cross-referenced to its JML ticket number.

Control 2 — Audit Controls (Access Logging)

Checklist item: "Log all access to ePHI in an access log" · 45 CFR §164.312(b)

Evidence Type	CloudTrail event history exports, VPC Flow Log samples, GuardDuty findings summary, Samba4 authentication log excerpts
Collection Technique	Export a 7-day CloudTrail event history filtered to IAM and data-access events; pull a sample window of VPC Flow Logs and the current GuardDuty findings list from the security dashboard built in Week 7; export Samba4 authentication logs for the same window
Documentation Standard	Each log export is timestamped, hashed or checksummed where practical, and stored with a short description of what it demonstrates (e.g., "CloudTrail export, Sep 23–29, confirms IAM console access is logged with user identity and source IP"). Retention target noted for Section 4: minimum 6 years per HIPAA documentation-retention requirements.

Control 3 — Login/Logout and Automatic Session Termination

Checklist item: "Document proper login and log out procedures for staff to safeguard ePHI" · 45 CFR §164.312(a)(2)(iii)

Evidence Type	Domain password/lockout policy export, Entra ID Conditional Access/session policy screenshots, SAML federation session-timeout configuration, documented login/logout procedure
Collection Technique	Export the domain policy with <code>samba-tool domain passwordsettings show</code> ; screenshot the Entra ID Conditional Access session controls and the Authentik SAML session-lifetime setting used in the MFA Support activity; review the written staff login/logout procedure against observed behavior during a test sign-in
Documentation Standard	Configuration exports and screenshots are paired with the written procedure they verify, filed together in the evidence log under one control reference, with a pass/fail note on whether the configured timeout matches the documented procedure.

3. Compliance Assessment

3.1 Testing Methodology Applied

For each control, the Inquire/Examine/Test methodology from Section 1.2 was applied: the IAM administrator role was asked how the control is configured (Inquire); the relevant HVMC policy and prior JML tickets were reviewed (Examine); and the live system was checked directly against the requirement (Test). Findings below are the result of the Test step and are illustrative/simulated for this lab exercise, consistent with how audit and incident findings are handled elsewhere in this capstone's compliance deliverables.

3.2 Findings Summary

Control	Finding
1 — Unique User ID	29 of 30 sampled accounts across AD, Entra ID, and AWS IAM map to a single named individual with no shared credentials. One legacy AWS IAM account created during initial lab setup was found without a clear individual owner.
2 — Audit Controls	CloudTrail, VPC Flow Logs, and GuardDuty are enabled and actively logging; Samba4 authentication logging is active on the domain controller. No formal log-retention schedule meeting the 6-year HIPAA documentation requirement has been configured in either environment.
3 — Login/Logout	Entra ID Conditional Access enforces MFA and a session sign-in frequency control; the SAML (Authentik) session lifetime is configured and was verified during the MFA Support activity. A written staff login/logout procedure exists but has not yet been distributed or acknowledged by workforce members in the lab roster.

3.3 Gap Analysis

Control	Required State	Current State	Gap	Risk Rating
1 — Unique User ID	Every account mapped to exactly one accountable individual	1 legacy AWS IAM account with no individual owner on file	Orphaned/unattributed account not tied to a JML record	MEDIUM
2 — Audit Controls	Access logs retained per the HIPAA 6-year documentation standard	Logging enabled, but no retention policy configured	No log-retention configuration in CloudTrail/GuardDuty or on the domain controller	HIGH

3 — Login/Logout	Documented procedure distributed to and acknowledged by all workforce members	Procedure written and technically enforced, not yet distributed/acknowledged	No workforce sign-off / training record for the procedure	MEDIUM
------------------	---	--	---	--------

4. Remediation Plan

4.1 Prioritized Recommendations

Priority	Recommendation	Control Addressed	Owner (acting role)	Target
1	Configure a retention policy on CloudTrail/GuardDuty log storage and the domain controller's authentication logs to meet the 6-year HIPAA retention standard	2 — Audit Controls	IAM/Identity Administrator	Within 30 days
2	Identify the individual accountable for the orphaned AWS IAM account (or deprovision it) and open a backfilled JML record	1 — Unique User ID	IAM/Identity Administrator	Within 15 days
3	Distribute the written login/logout procedure to all workforce members in the lab roster and collect signed acknowledgments	3 — Login/Logout	HR / Workforce Alliance liaison	Within 30 days

4.2 Implementation Timeline

Window	Milestones
Days 1–15	Resolve the orphaned AWS IAM account (Recommendation 2); begin configuring log-retention settings (Recommendation 1)
Days 16–30	Complete log-retention configuration and verify a 6-year retention window is enforced; distribute and begin collecting acknowledgments for the login/logout procedure (Recommendation 3)
Day 45	Progress check-in: confirm acknowledgment completion rate and retention configuration evidence
Day 90	Re-test all three controls and close out the remediation cycle

4.3 Progress Tracking Methods

- **Remediation tracker:** each recommendation above is logged as its own tracked item with owner, target date, and status (Open / In Progress / Complete), reviewed weekly until closed.
- **KPI monitoring:** percentage of accounts with a confirmed individual owner, percentage of workforce members with an acknowledged login/logout procedure, and confirmation that log retention is configured and verified (yes/no), each reviewed at the 30- and 90-day checkpoints.
- **Re-test:** all three controls are re-tested at Day 90 using the same Inquire/Examine/Test methodology from Section 1.2, and the gap analysis in Section 3.3 is updated to reflect closed items.

Source reference: HIPAA Journal, HIPAA Compliance Checklist (uploaded reference document). Prepared as part of the Compliance Auditing Basics deliverable for the Semester 4 Healthcare IAM Operations Home Lab capstone.